

Security+ 2.3 · Buffer Overflows

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — Buffer Overflows (3:37) · [vídeo original ↗](#) · [YouTube ↗](#)

Escreve MAIS dado do que o buffer aguenta = sobrescreve memória adjacente (pode ser shellcode). Defesa: bounds checking, DEP/ASLR, secure coding, compilar com proteção.

💡 Highlights que a prova cobra

- Buffer overflow: escreve além do tamanho do buffer
- DEP: barra execução na heap/stack; ASLR: randomiza endereços

🎯 Dicas de prova

- 'application writes beyond allocated memory' = buffer overflow
- 'randomizes memory addresses' = ASLR

Cenário clássico: Cenário: 'application crashes when input longer than expected is sent' = buffer overflow (a base de exploit).

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:
 - A)** Escalada de privilégio (privilege escalation)
 - B)** Negação de serviço
 - C)** Engenharia social
 - D)** Sniffing

2. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Buffer overflow: escreve além do tamanho do buffer'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Buffer overflow: escreve além do tamanho do buffer...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'DEP: barra execução na heap/stack; ASLR: randomiza endereços'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DEP: barra execução na heap/stack; ASLR: randomiza endereços...

4. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'application writes beyond allocated memory' = buffer overflow'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'application writes beyond allocated memory' = buffer overflow...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'randomizes memory addresses' = ASLR'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'randomizes memory addresses' = ASLR...

6. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'application crashes when input longer than expected is sent' = buffer overflow (a base de exploit)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'application crashes when input longer than expected is sent' = bu...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Buffer overflow: escreve além do tamanho do buffer'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Buffer overflow: escreve além do tamanho do buffer...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'DEP: barra execução na heap/stack; ASLR: randomiza endereços'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DEP: barra execução na heap/stack; ASLR: randomiza endereços...

9. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'application writes beyond allocated memory' = buffer overflow'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'application writes beyond allocated memory' = buffer overflow...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Buffer Overflows): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'randomizes memory addresses' = ASLR'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'randomizes memory addresses' = ASLR...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Escalada de privilégio (privilege escalation).** Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia.
- 2) C — Implementar a solução correspondente: Buffer overflow: escreve além do tamanho d.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): Buffer overflow: escreve além do tamanho do buffer. As demais alternativas configuram violações graves de conformidade
- 3) D — Implementar a solução correspondente: DEP: barra execução na heap/stack; ASLR: r.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): DEP: barra execução na heap/stack; ASLR: randomiza endereços. As demais alternativas configuram violações graves de
- 4) B — Implementar a solução correspondente: 'application writes beyond allocated memor.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): 'application writes beyond allocated memory' = buffer overflow. As demais alternativas configuram violações graves de
- 5) D — Implementar a solução correspondente: 'randomizes memory addresses' = ASLR....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): 'randomizes memory addresses' = ASLR. As demais alternativas configuram violações graves de conformidade ou falhas de
- 6) B — Implementar a solução correspondente: Cenário: 'application crashes when input l.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): Cenário: 'application crashes when input longer than expected is sent' = buffer overflow (a base de exploit).. As de
- 7) A — Implementar a solução correspondente: Buffer overflow: escreve além do tamanho d.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): Buffer overflow: escreve além do tamanho do buffer. As demais alternativas configuram violações graves de conformidade
- 8) D — Implementar a solução correspondente: DEP: barra execução na heap/stack; ASLR: r.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): DEP: barra execução na heap/stack; ASLR: randomiza endereços. As demais alternativas configuram violações graves de
- 9) B — Implementar a solução correspondente: 'application writes beyond allocated memor.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): 'application writes beyond allocated memory' = buffer overflow. As demais alternativas configuram violações graves de
- 10) C — Implementar a solução correspondente: 'randomizes memory addresses' = ASLR....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Buffer Overflows): 'randomizes memory addresses' = ASLR. As demais alternativas configuram violações graves de conformidade ou falhas de

